



FILE PATH TRANSVERSAL

ROAD TO HALL OF FAME



BRYHAN EDUARDO GUZMAN MARTINEZ

178508

SEGURIDAD INFORMÁTICA

Índice

1. Marco Teórico y Fundamentación Técnica	2
Concepto y Funcionamiento	2
Relación con Estándares y Principios.....	2
2. Información del Laboratorio	2
3. Explicación Técnica de la Vulnerabilidad.....	2
4. Explicación Técnica del Payload	3
5. Procedimiento Paso a Paso y Uso Técnico de Burp Suite	3
6. Evidencias y Capturas de Pantalla	4
7. Mitigación Recomendada	10

1. Marco Teórico y Fundamentación Técnica

Concepto y Funcionamiento

El *File Path Traversal* (o *Directory Traversal*) es una vulnerabilidad de seguridad web que ocurre cuando una aplicación utiliza entradas proporcionadas por el usuario para construir rutas de acceso a archivos en el servidor sin la debida sanitización. Esto permite a un atacante manipular los parámetros de lectura para navegar a través del árbol de directorios del sistema de archivos y leer archivos arbitrarios dentro del servidor.

Relación con Estándares y Principios

- **OWASP Top 10:** Se clasifica dentro de la categoría **A01:2021 – Broken Access Control (Control de Acceso Deficiente)**, ya que el sistema falla en restringir el acceso del usuario únicamente a los recursos autorizados.
- **Modelo CIA (Confidencialidad, Integridad y Disponibilidad):** Atenta de forma directa contra la **Confidencialidad**, ya que permite exponer información sensible del sistema operativo o la aplicación (credenciales, configuraciones, clave de API, etc.) a usuarios no autorizados.

2. Información del Laboratorio

1. **Nombre del laboratorio:** File path traversal, simple case
2. **Nivel:** Apprentice
3. **Tipo de explotación:** In-band / Out-of-band File Read (Lectura arbitraria de archivos del sistema de archivos)
4. **Objetivo del laboratorio:** Recuperar e inspeccionar el contenido del archivo /etc/passwd

3. Explicación Técnica de la Vulnerabilidad

La vulnerabilidad reside en la forma en que la aplicación web gestiona la carga de imágenes dinámicas. La aplicación recibe un parámetro GET denominado filename:

GET /image?filename=30.jpg

El backend toma el valor del parámetro filename y lo concatena directamente con la ruta base de almacenamiento de imágenes (ejemplo: /var/www/images/30.jpg). Al no existir validación de caracteres especiales ni listas blancas, el servidor interpreta secuencias de escape de directorio (../), lo que permite retroceder niveles en la estructura de carpetas del sistema operativo.

4. Explicación Técnica del Payload

- **Payload utilizado:** ../../../../etc/passwd
- **Mecanismo de funcionamiento:**
 - **Secuencia de escape (../):** Cada ../ le indica al sistema operativo que suba un nivel en la jerarquía de directorios.
 - **Profundidad de navegación:** Se emplean cuatro secuencias (../../../../) para asegurar que la consulta escale hasta el directorio raíz (/) del sistema de archivos de Linux, independientemente de la profundidad de la carpeta donde esté alojada la aplicación.
 - **Ruta objetivo (/etc/passwd):** Es el archivo estándar en sistemas base Unix/Linux que contiene información sobre las cuentas de usuario registradas.

5. Procedimiento Paso a Paso y Uso Técnico de Burp Suite

1. **Inicio del laboratorio:** Acceso a la instancia del laboratorio mediante la plataforma PortSwigger (*Imagen 1*).
2. **Obtención del dominio objetivo:** Se abre la aplicación e identifica la URL asignada (*Imagen 2*).
3. **Configuración de Burp Suite:** Se inicia Burp Suite Community Edition utilizando un proyecto temporal en memoria (*Imagen 3 y 4*).
4. **Activación del Proxy:** En la pestaña **Proxy**, se accede al botón de intercepción para habilitar el navegador embebido de Burp (*Imagen 5 y 6*).
5. **Navegación y captura de tráfico:** Se ingresa a la URL del laboratorio desde el navegador interceptado para generar peticiones HTTP (*Imagen 7 y 8*).
6. **Aislamiento del punto vulnerable:** Se identifica la petición GET /image?filename=30.jpg HTTP/2 encargada de servir los recursos multimedia (*Imagen 9*).
7. **Traspaso a Repeater:** Se realiza clic derecho sobre la petición capturada y se envía al módulo **Repeater** (Ctrl + R) para manipular los parámetros (*Imagen 10*).
8. **Inyección y ejecución del payload:** En la sección **Repeater**, se modifica el parámetro filename=30.jpg por filename=../../../../../../etc/passwd y se presiona **Send** (*Imagen 11 y 12*).

9. **Verificación de la respuesta:** En el panel **Response**, el servidor responde con un estado HTTP/2 200 OK devolviendo el contenido del archivo `/etc/passwd` (Imagen 13).
10. **Confirmación de resolución:** Al refrescar la plataforma principal del laboratorio, se confirma el estado **Solved** (Imagen 14).

6. Evidencias y Capturas de Pantalla

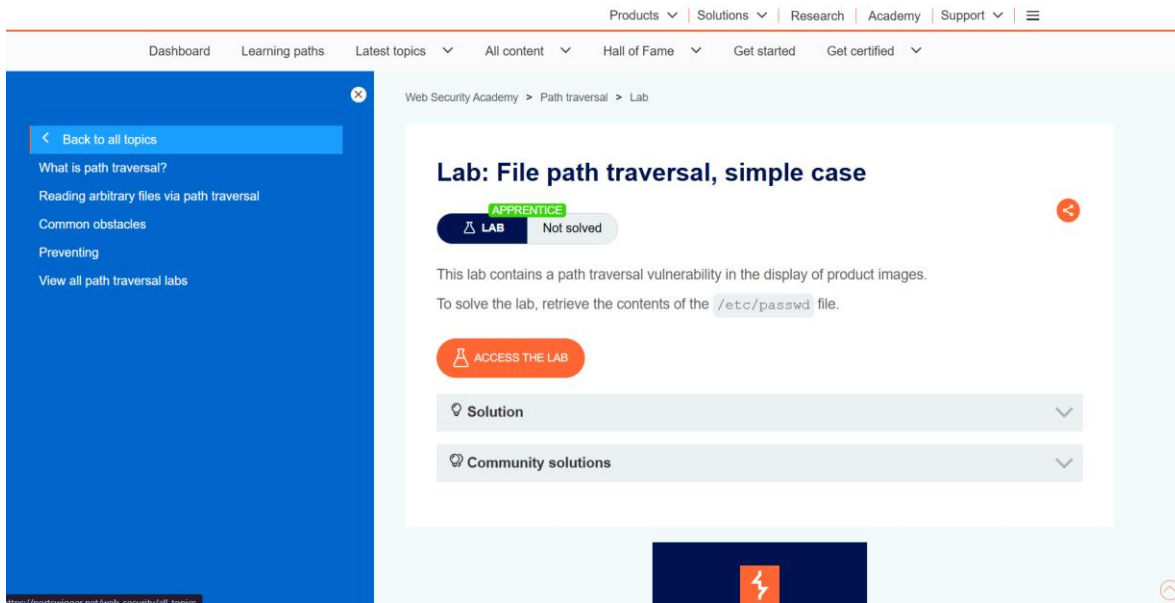


Imagen 1. Tenemos el laboratorio 1 Lab: File Path Transversal, primero hacemos click en “ACCESS THE LAB”

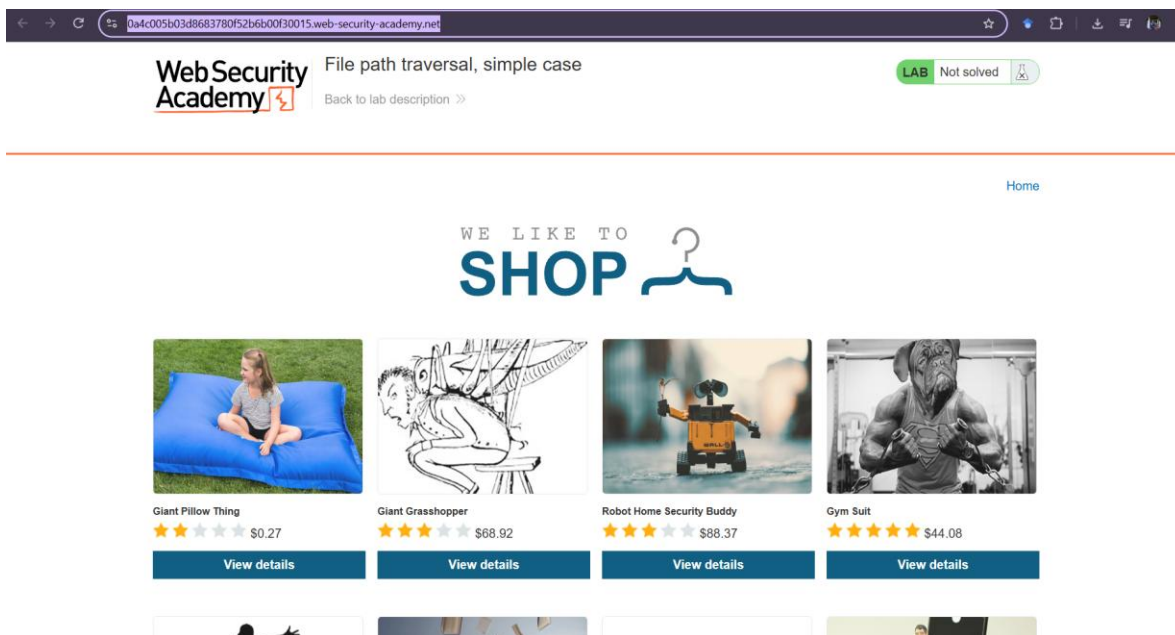


Imagen 2. Nos abre una página que nos arroja un URL el cual tenemos que copiar

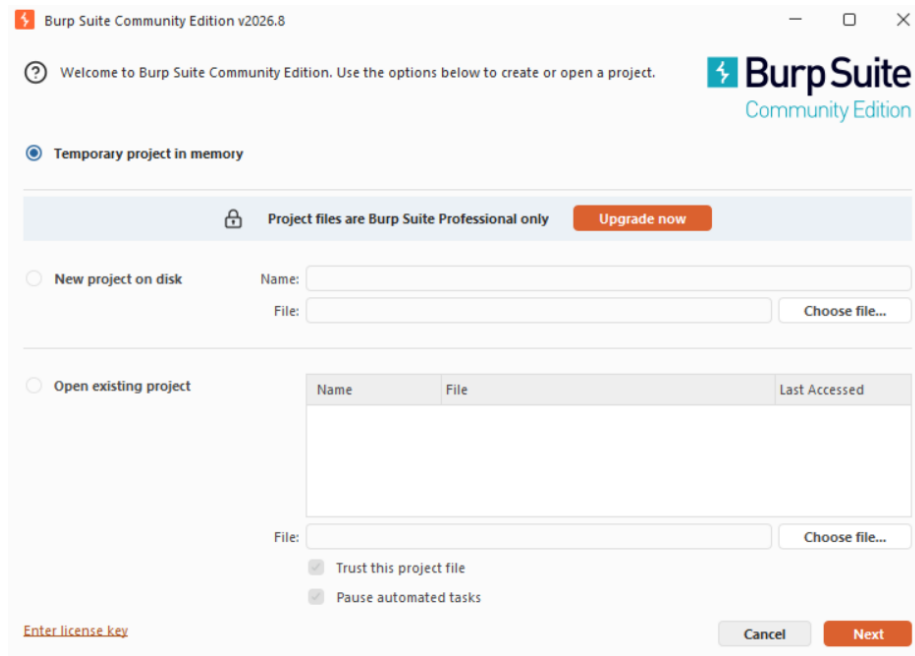


Imagen 3. Abrimos BurpSuit previamente descargado, seleccionamos “Temporary Project in memory”, después demos click en “Next”

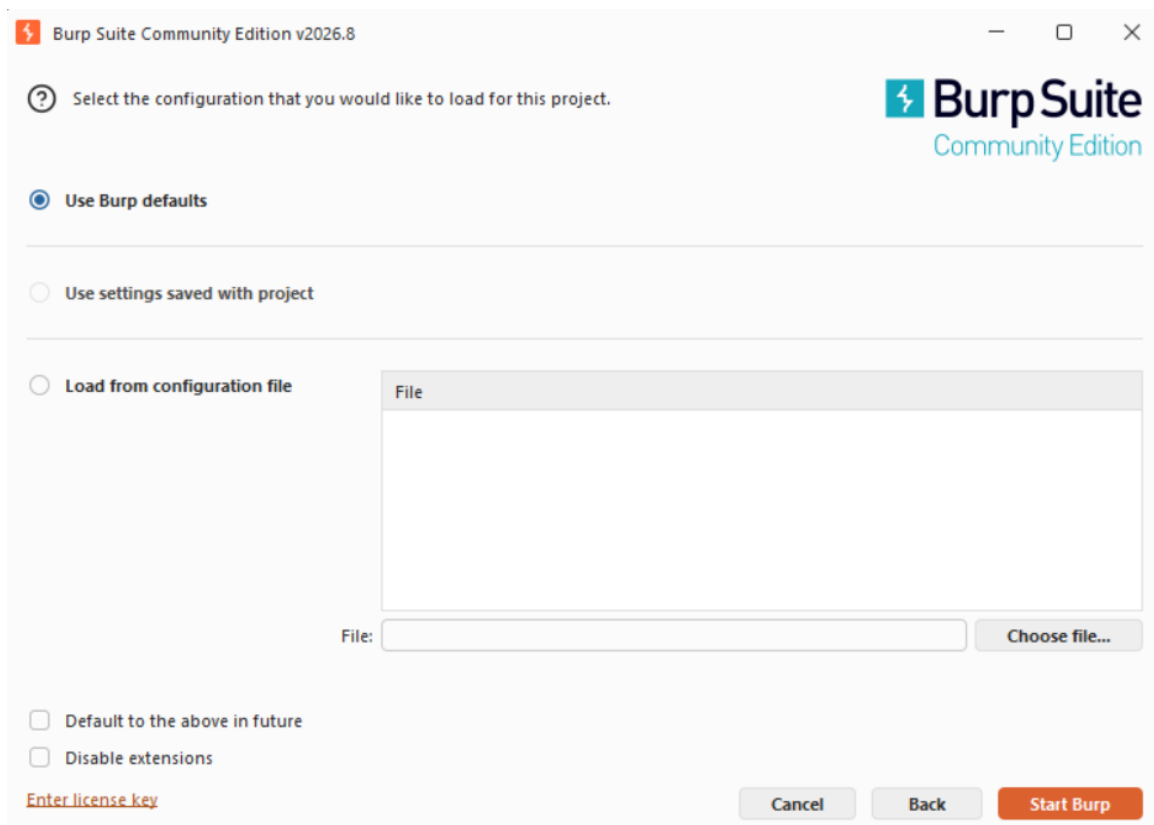


Imagen 4. Seleccionamos “Use Burp defaults” y damos click en “Start Burp”.

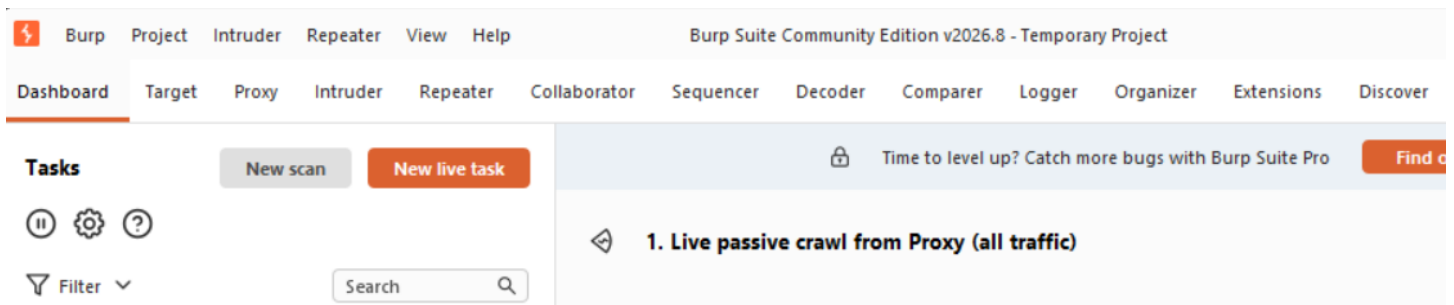


Imagen 5. El las pesañas que están arriba, daremos click en “Proxy”

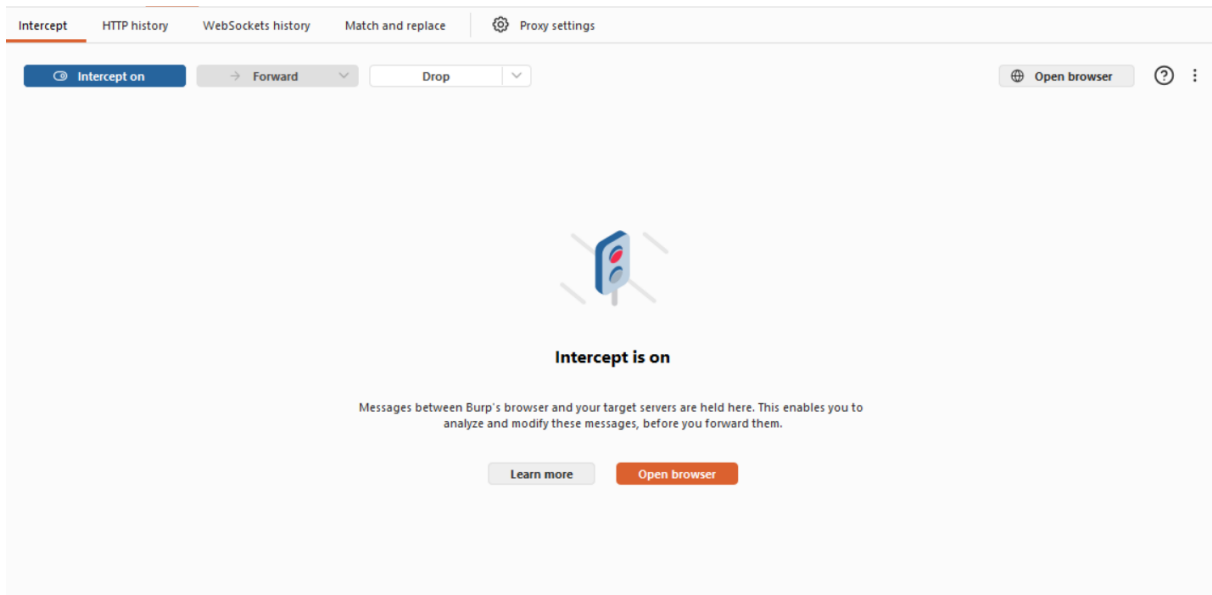


Imagen 6. Daremos click en “Intercept on” para que cambie a “Intercept off” después daremos click en open browser.

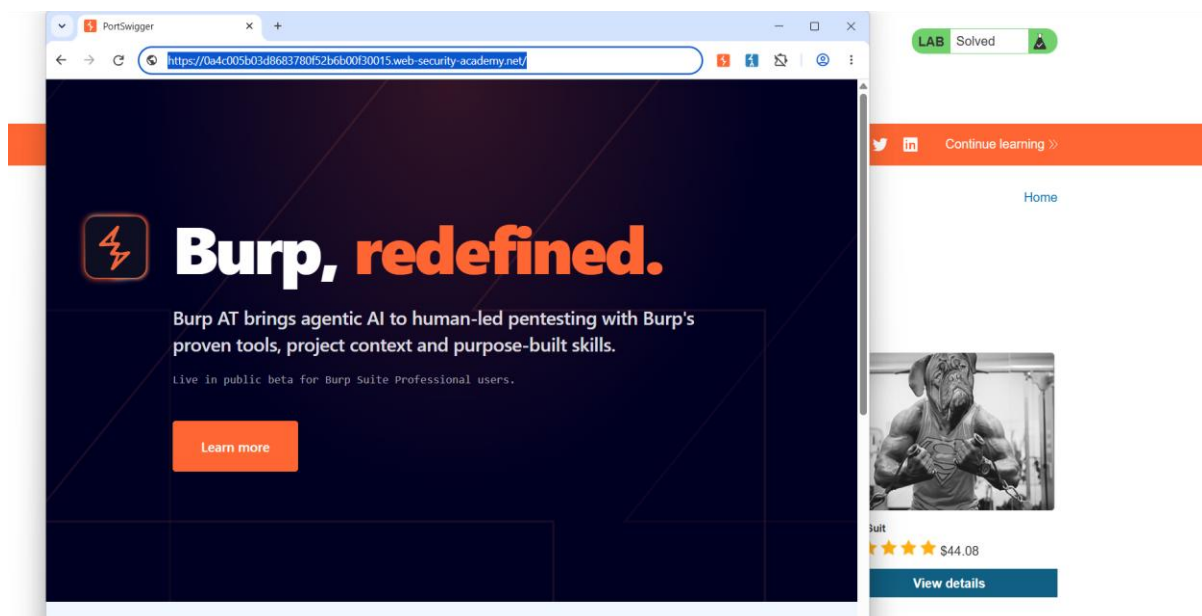


Imagen 7. Se abrirá una pestaña del navegador donde pegaremos la URL que nos dieron cuando accedimos al laboratorio (imagen 2)

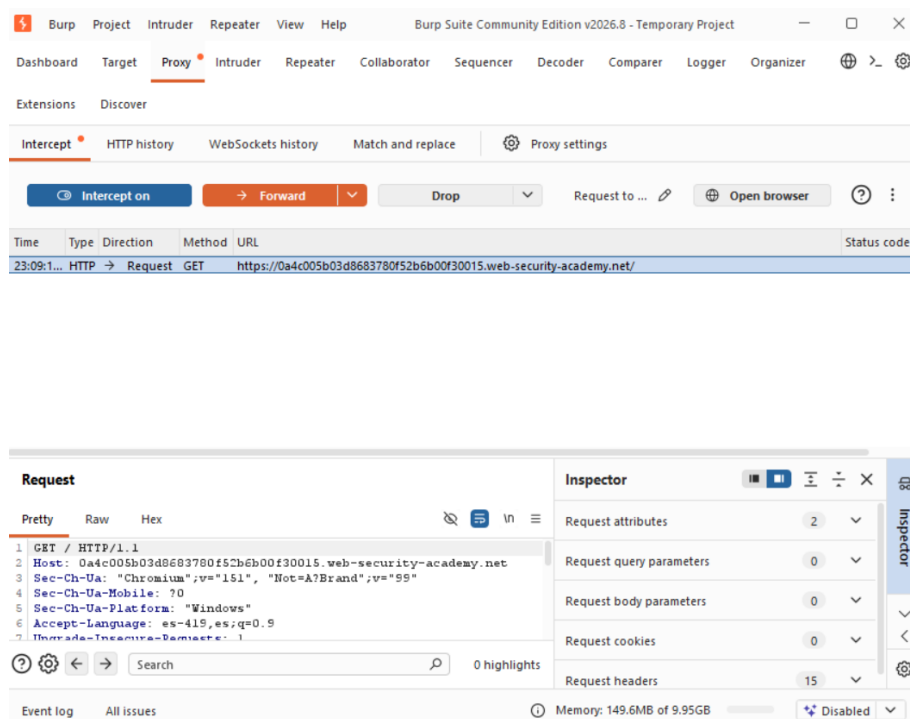


Imagen 8. En BurpSuite nos aparecerá un archivo HTTP, donde presionaremos “FOWARD”

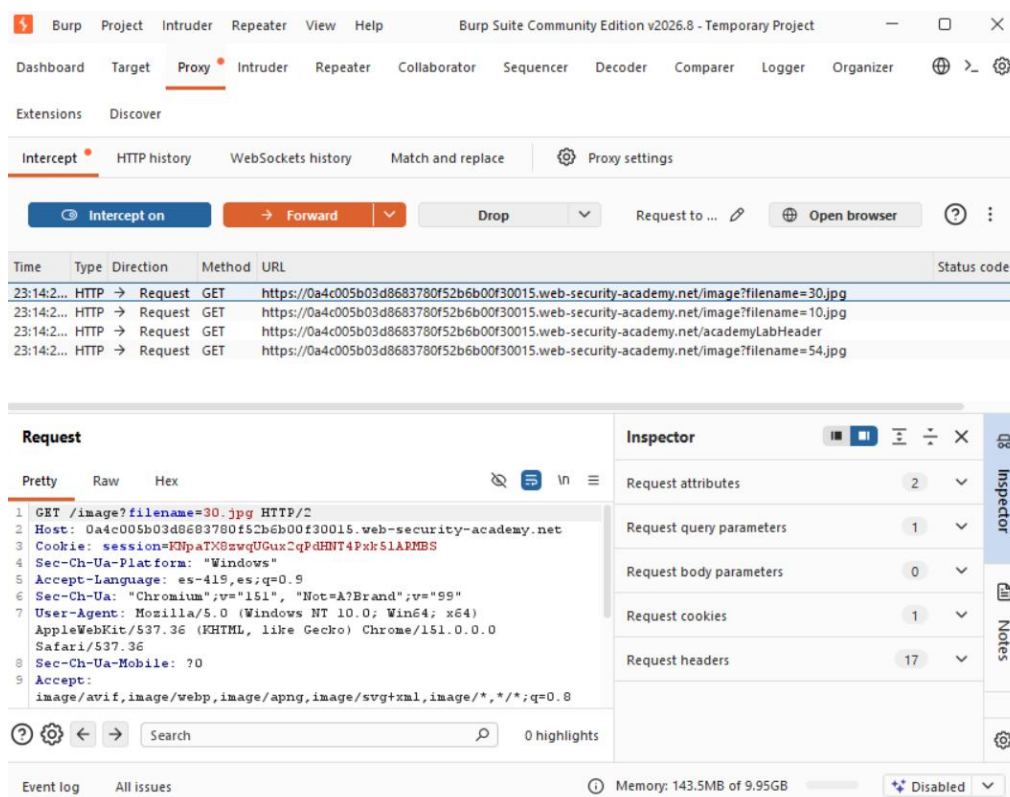


Imagen 9. Se abrirán mas archivos, el que ocuparemos será el que dice “GET /image?filename=30.jpg HTTP/2”.

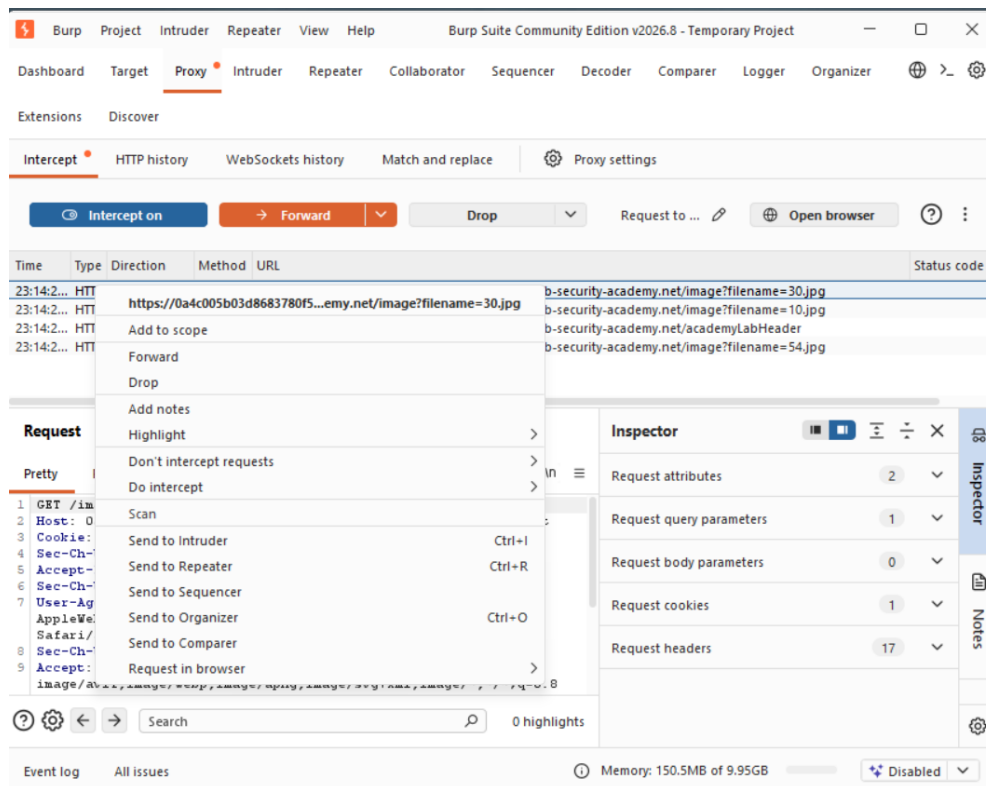


Imagen 10. El cual seleccionaremos daremos click y pondremos la opción “Send to Repeater”

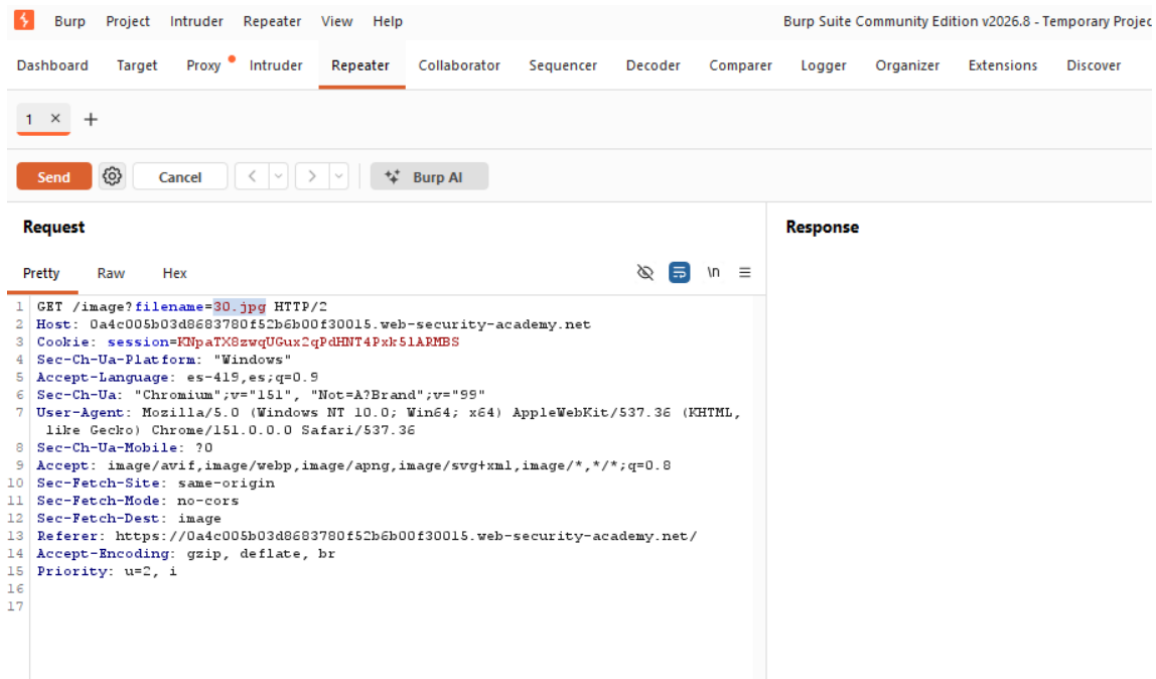


Imagen 11. Nos iremos a la pestaña que se encuentra en la parte superior “Repeater” y la parte que cambiaremos será la seleccionada (30.jpg)

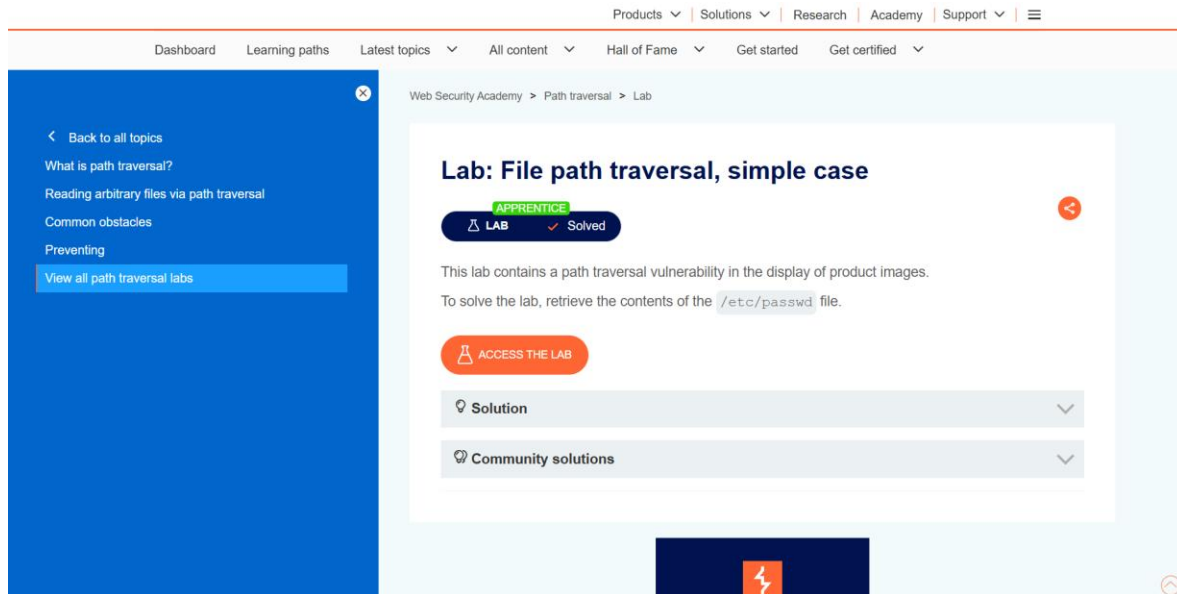


Imagen 14. En la página del laboratorio aparecerá que ya está resuelto ese laboratorio (Solved ✓)

7. Mitigación Recomendada

Para erradicar la vulnerabilidad de File Path Traversal de forma efectiva, se deben implementar las siguientes medidas defensivas:

1. **Evitar la transferencia de nombres de archivo por el usuario:** Utilizar identificadores numéricos (por ejemplo, id=30) asociados a una base de datos en lugar de nombres de archivos físicos en la solicitud HTTP.
2. **Validación y Sanitización:**
 - Aplicar listas blancas (*whitelisting*) para permitir únicamente nombres de archivos que contengan caracteres alfanuméricos y extensiones válidas (.png, .jpg).
 - Descartar cualquier petición que contenga secuencias ../, slashes o caracteres de control.
3. **Uso de APIs seguras del sistema de archivos:**
 - Utilizar funciones que resuelvan la ruta absoluta antes de abrir el archivo (ej. canonicalPath en Java o realpath() en PHP) y verificar que la ruta comience estrictamente dentro del directorio base permitido (ej. /var/www/images/).
4. **Principio de Mínimo Privilegio:** Configurar el proceso que ejecuta el servidor web con permisos de lectura restringidos dentro del sistema operativo, impidiendo el acceso a archivos del sistema como /etc/passwd o archivos de configuración.